

Protecting Radiology Data and Devices Against Cybersecurity Threats: A Joint White Paper of the ACR and Society for Imaging Informatics in Medicine¹

Po-Hao Chen, MD, MBA^{a,b}, Benoit Desjardins, MD, PhD^c, Brett Strassner, MA^d,
Reza Forghani, MD, PhD^e, Robert Bodak^f, Judy Gichoya, MD, MS^g, James Whitfill, MD, MBA^{h,i},
Eric C. Ehman, MD^j, Christoph Wald, MD, PhD, MBA^k

Credits awarded for this enduring activity are designated “CME” by the American Board of Radiology (ABR) and qualify toward fulfilling requirements for Maintenance of Certification (MOC) Part II: Lifelong Learning and Self-assessment. To access the CME activity visit <https://cortex.acr.org/Presenters/CaseScript/CaseView?Info=UIruBIUOzJLEwc2IyouAW6tQSzfZkW8u0Hhw9sisNM%253d>. CME credit for this article expires September 30, 2026. All CME articles can be found on JACR.org by navigating to CME on the dropdown menu.

Abstract

Modern radiology relies entirely on digital imaging systems. Health care records draw cybercriminals’ attention. On-site and cloud-based informatics systems, including artificial intelligence, can boost efficiency but also create weak points. Medical imaging systems must safeguard patient identities, control access, secure devices, and coordinate with patients, payers, and billing partners. Endorsed by the ACR and the Society for Imaging Informatics in Medicine, this white paper outlines steps to fortify the medical imaging pipeline methodically, train caregivers on the frontline, and develop incident response and recovery strategies for data breaches and disabling ransomware attacks. Additionally, building a culture of safety in imaging involves conducting routine simulations and actively engaging

^aVice Chair for Artificial Intelligence, Enterprise Diagnostics Institute, Cleveland Clinic, Cleveland, Ohio.

^bCleveland Clinic Lerner College of Medicine, Case Western Reserve University, Cleveland, Ohio; Chair, Data Science Summit, American College of Radiology; Chair, Security Subcommittee, Society for Imaging Informatics in Medicine.

^cChief Medical Information Officer, Centre Hospitalier de l’Université de Montréal, Montréal, Quebec, Canada.

^dRadiation Protection Services Limited, Springfield, Illinois.

^eChief of Imaging Informatics, Department of Radiology, AdventHealth Medical Group Central Florida Division, Maitland, Florida.

^fSection of Imaging Informatics, Enterprise Diagnostics Institute, Cleveland Clinic, Cleveland, Ohio.

^gDirector of Healthcare Innovation and Translational Informatics Lab, Department of Radiology & Imaging Sciences, Emory University, Atlanta, Georgia.

^hHonorHealth, Scottsdale, Arizona.

ⁱArizona State University School of Medicine and Advanced Medical Engineering, Phoenix, Arizona; Senior Vice President, Chief Transformation Officer, HonorHealth.

^jLead, Artificial Intelligence and Informatics, Abdominal Imaging Division, Department of Radiology, Mayo Clinic, Rochester, Minnesota; Chair, Mayo Clinic Enterprise Radiology Downtime Committee.

^kDepartment of Radiology, Mayo Clinic, Rochester, Minnesota; Chair, Commission on Informatics and Vice Chair, Board of Chancellors, ACR.

Corresponding author and reprints: Po-Hao Chen, MD, MBA, Section of Imaging Informatics, Cleveland Clinic, 9500 Euclid Ave, Mail Code JJ3, Cleveland, OH 44195; e-mail: chenp2@ccf.org.

Po-Hao Chen, MD, MBA, reports relationships with Siemens Healthineers AG, National Institute of Health, and Arthritis Foundation that includes funding grants. Reza Forghani, MD, PhD, reports relationships with Nuance Communications Inc, Canon Medical Systems Corporation, General Electric Company, National Institute of Health and National Science Foundation that include funding grants; a relationship with Canon Medical Systems Corporation that includes nonfinancial support and speaking and lecture fees; relationships with PaxeraHealth Corp and Neuropacs Corp that include consulting or advisory; and has patent #US11257210B2 issued to Royal Institution for the Advancement of Learning. Judy Gichoya, MD, MS, reports relationships with National Bureau of Economic Research, Cook Medical LLC, and APPOS CME that include speaking and lecture fees; relationships with Lunit Inc, Clarity Consortium, and Bunkerhill Foundation that include funding grants. Christoph Wald, MD, PhD, MBA reports a relationship with Deepc that includes consulting or advisory and equity or stocks and a relationship with Radpair that includes consulting or advisory. The other authors state that they have no conflict of interest related to the material discussed in this article. All authors are non-partner/non-partnership track/employees.

¹ This paper was jointly developed by Journal of the American College of Radiology and Journal of Imaging Informatics in Medicine and jointly published by Elsevier and Springer Nature. The articles are identical except for minor stylistic and spelling differences in keeping with each journal’s style. Either citation can be used when citing this article.

leadership. Taken together, these multidisciplinary interventions can minimize the clinical impact and operational implications of cybersecurity events, thereby maintaining patient trust in an increasingly interconnected imaging workflow.

Key Words: ACR, cybersecurity, privacy, radiology, ransomware

J Am Coll Radiol 2025;22:1160-1172. © 2025 Published by Elsevier Inc. on behalf of American College of Radiology and Springer Nature on behalf of the Society for Imaging Informatics in Medicine. All rights are reserved, including those for text and data mining, AI training, and similar technologies.

INTRODUCTION

Modern radiology practice is fully digital, relying on the continuous and seamless operation of digital imaging assets, databases, and communication systems. At the same time, health care data are highly valuable to cybercriminals, making these records prime targets for breaches. In 2024, the Office of Civil Rights reported 725 data breaches and ransomware attacks [1]. In 2024, the most significant breach to date affected an estimated 190 million individuals and crippled business operations for many practices [2].

The portability and interoperability of digital data and the use of on-site and off-site networked computers have invited a host of vulnerabilities. Practices must protect authorized user identities, manage user behavior, access control, and networked devices, as well as on- and off-campus compute resources, and external partners such as patients, payers, and billing companies. These interconnected systems, often requiring updates and maintenance, necessitate robust cybersecurity measures. In his 2022 white paper, “Cybersecurity Is Patient Safety,” US Senator Warner and his team discuss important imperatives for practice, including minimum cyber hygiene practices, cyber emergency preparedness, and cyber insurance [3].

In this white paper, we discuss strategies to mitigate risk and restore normal operations in the event of an attack. This collaborative white paper is endorsed by the ACR and the Society for Imaging Informatics in Medicine (SIIM) and is intended to replace the existing 2019 ACR-AAPM-SIIM Practice Parameter for Electronic Medical Information Privacy and Security.

COMPOSITION OF THE WHITE PAPER WORKING GROUP

A joint white paper working group was convened by the ACR and SIIM, consisting of nine multidisciplinary members charged with developing consensus recommendations:

- **Po-Hao Chen, MD, MBA**—Chair of the SIIM Security Subcommittee and a member of the ACR Commission on Informatics. Also serving as Vice Chair of Enterprise Diagnostics Institute and Former Chief Informatics Officer for Imaging at the Cleveland Clinic, Dr Chen frequently publishes and presents at national conferences on informatics policy, operational resilience, and ransomware recovery readiness.
- **Benoit Desjardins, MD, PhD**—Chief medical information officer and cardiovascular radiologist at Centre Hospitalier de l'Université de Montréal. A recognized authority in artificial intelligence (AI) and medical imaging cybersecurity, Dr Desjardins holds multiple security certifications and regularly presents on cybersecurity topics at national and international forums. He serves on SIIM Security Subcommittee and Healthcare Information and Management Systems Society Cybersecurity, Privacy and Security Committee.
- **Brett Strassner, MA**—Medical physicist at Radiation Protection Services and member of the SIIM Security Subcommittee. A certified imaging informatics professional, Mr Strassner brings expertise in device-level security and technical informatics solutions.
- **Reza Forghani, MD, PhD**—Chief of imaging informatics at AdventHealth Medical Group, Central Florida Division, and a member of the ACR Commission on Informatics. Dr Forghani has led the design and deployment of enterprise-wide health informatics, AI solutions, and secure imaging platforms across large health systems.
- **Robert Bodak**—Imaging informatics analyst with extensive experience as a radiology technologist. Mr Bodak advises on imaging data and device implementation and coordinates radiology downtime planning at Cleveland Clinic. He is also an active member of the SIIM Security Subcommittee.
- **Judy Gichoya, MD, MS**—Associate professor in Emory University's Department of Radiology & Imaging Sciences, Dr Gichoya is a SIIM Board of Directors member and a member of the ACR Commission on Informatics. She directs Emory's Healthcare AI Innovation and Translational Informatics Lab, focusing on secure machine learning pipelines and health equity.
- **James Whitfill, MD, MBA**—Senior vice president and chief transformation officer at HonorHealth and Adjunct Faculty at Arizona State University. Dr Whitfill authored the “Data Security and Privacy” chapter in *Practical Imaging Informatics*, coauthored the 2019 ACR-AAPM-SIIM practice parameter, and served as SIIM Board Chair from 2018 to 2020 [4]. He has lectured in national settings on cybersecurity in health care and testified to CMS on cybersecurity of medical devices.

- **Eric Ehman, MD**—Chair of the Mayo Clinic Enterprise Radiology Downtime Committee and Lead for AI & Informatics in the Abdominal Imaging Division. Dr Ehman has led resilience planning for radiology systems outages and secure AI deployments across Mayo sites.
- **Christoph Wald, MD, PhD, MBA**—Chair of the ACR Commission on Informatics and Vice Chair of the ACR Board of Chancellors. Dr Wald founded ACR's Cybersecurity Resource Hub by securing partnerships with device manufacturers and US agencies and has championed comprehensive cyber-resilience planning nationally, bringing both policy insight and practical risk-management expertise.

Members were selected for their contribution to radiology informatics, cybersecurity, incident resilience planning, and organizational leadership. [Table 1](#) presents a summary of affiliations and leadership roles.

HOW THIS ARTICLE IS ORGANIZED

We organize the white paper in two axes. First, a landscape overview outlines vulnerabilities of the modern radiology practice. This description encompasses hardware, software, and data within the context of modern growth in remote work, AI, and image sharing, addressing a decentralized but interconnected radiology practice, patient base, and technology infrastructure. The second axis is a toolkit, consisting of safeguards rooted in best practices, regulatory requirements, and technical advancements.

Effective cybersecurity requires an organization-wide approach, with each element deserving action from business leaders, radiologists, technologists, and informatics professionals alike. The article includes two actionable checklists. The Cybersecurity Checklist for the Radiology Leadership ([Table 2](#)) emphasizes operational readiness through the lens of a clinical and operational leader, whereas the Checklist for Identifying Vulnerable Imaging Technology ([Table 3](#)) contains more technical granularities through the lens of imaging informatics. Some technical jargon was unavoidable in the checklists, but where relevant, it is explained in this text.

VULNERABILITIES IN RADIOLOGY OPERATIONS

Radiology imaging equipment has an operational expectancy that varies from 7 years for an ultrasound unit to 10 years for general radiography equipment [5]. The age of the equipment often poses a risk due to a lack of security features and operating system updates [6]. All available equipment and devices that are connected to a radiology department or practice's medical imaging ecosystem, including

the virtual end points (eg, servers and routers) and physical access (eg, USB ports), comprise the department's attack surface. Attack surfaces may be managed with a cybersecurity hygiene routine that is tailored to the imaging environment [7]. Supplementing this section is [Table 3](#), the Checklist for Identifying Vulnerable Imaging Technology, which offers an actionable tool for enumerating vulnerable technology and mitigating cybersecurity processes for operational continuity.

Hardware Infrastructure

Many radiology practices and hospitals continue to own physical storage and computing hardware. However, hospital policies and assigned technical responsibilities can shape radiology security practices, sometimes limiting the ability to adopt ideal cyber-hygiene measures. Additionally, the radiology information and PACS remain commonly deployed on premises. Servers could reside within or immediately adjacent to the hospital and be directly connected (ie, "hardwired") to the intranet, or they may reside in a data center and be connected through a site-to-site virtual private network. Even when on premises, modern radiology servers often establish Internet connections to external cloud-based platforms or remote support services, introducing dependencies and vulnerabilities and driving considerations of performance, cost, latency, and regulatory compliance beyond physical location.

Securing imaging hardware, including modalities and workstations, has become increasingly challenging as imaging practices become more integrated into the broader world. Cybersecurity hygiene practices such as regularly updating software, using complex passwords, implementing multifactor authentication, placing equipment behind firewalls, and conducting regular security audits will assist in reducing risk [7].

Modality equipment also may have intrinsic, dedicated storage that offers temporary storage for images. Because such storage is temporary and limited, modalities are usually configured with image life cycle policies to purge older data automatically. During extended downtime, this temporary storage may become disconnected from central storage, making its image life cycle policies a risk for permanent data loss.

Data, Software, and Virtual Infrastructure

In addition to hardware-related considerations, imaging operations also depend on a growing list of informatics tools. There is a growing adoption of PACS and vendor-neutral archives for enterprise-wide imaging needs as well as increased use of advanced imaging and AI tools. These tools can be hosted entirely on premises using organization-owned hardware, on dynamically provisioned

Table 1. Key affiliations and informatics and cybersecurity leadership of working group members

Member	Credentials	Primary Affiliation	Leadership	Area of Expertise
Po-Hao Chen	MD, MBA	Cleveland Clinic; Case Western Reserve University	Chair of SIIM Security Subcommittee; member of ACR Commission on Informatics	Clinical and imaging informatics operations; business resilience; policy
Benoit Desjardins	MD, PhD, FAHA, FACR, FNASCI, CEH, CIISP, CIIP	Centre Hospitalier de l'Université de Montréal	Chief medical information officer; member of SIIM Security Subcommittee; member of HIMSS Cybersecurity Privacy and Security Committee	Health care cybersecurity; artificial intelligence; clinical workflow
Brett Strassner	MA, CIIP, CCT, CEH, COSINTP	Radiation Protection Services, Ltd	Member of SIIM Security Subcommittee	Medical physics; device security
Reza Forghani	MD, PhD	AdventHealth Medical Group, Florida	Chief of imaging informatics	Artificial intelligence; implementation; clinical workflow; policy
Robert Bodak	RT	Cleveland Clinic	Member of SIIM Security Subcommittee	Imaging workflow; contingency planning
Judy Gichoya	MD, MS, FSIIM	Emory University	Member of SIIM Board; ACR Commission on Informatics member	Radiology operations; artificial intelligence
James Whitfill	MD, MBA, FSIIM	HonorHealth; Arizona State University	SVP and chief transformation officer; prior SIIM chair of the board of directors	Digital health strategy; risk management
Eric C. Ehman	MD	Mayo Clinic	Chair of Mayo Clinic Enterprise Radiology Downtime Committee	Resilience planning; AI deployment security
Christoph Wald	MD, PhD, MBA	Mayo Clinic	Chair, ACR Commission on Informatics; vice-chair, ACR Board of Chancellors; prior chair of radiology	Radiology leadership; policy

AI = artificial intelligence; CCT = Certified Cyber Technician; CEH = Certified Ethical Hacker; CIIP = Certified Imaging Informatics Professional; CIISP = Certified Information Systems Security Professional; COSINTP = Certified Open Source Intelligence Professional; FACR = Fellow of the American College of Radiology; FAHA = Fellow of the American Heart Association; FNASCI = Fellow of the North American Society for Cardiovascular Imaging; FSIIM = Fellow of the Society for Imaging Informatics in Medicine; HIMSS = Healthcare Information and Management Systems Society; MA = Master of Arts; MBA = Master of Business Administration; MD = Doctor of Medicine; MS = Master of Science; RT = Radiologic Technologist; SIIM = Society for Imaging Informatics in Medicine; SVP = Senior Vice President.

Table 2. Cybersecurity Checklist for the Radiology Leadership

Category	Checklist Items
System and device security	☐ Is there a complete inventory of vulnerable radiology systems (see Checklist for Identifying Vulnerable Imaging Technology)? ☐ Are all software and hardware devices in the imaging chain regularly updated with the latest security patches? ☐ Are all systems and devices securely configured to minimize vulnerabilities? ☐ Is reliable antivirus and antimalware software installed and maintained on all end points and servers?
Data protection and privacy	☐ Is strong encryption used for data at rest and in transit? ☐ Are strict access control measures in place, such that only authorized personnel can access sensitive systems and data? ☐ Is the amount of personal and sensitive data collected and stored minimized to only what is necessary for clinical purposes?
Network security	☐ Are firewalls and intrusion detection systems deployed to monitor and control incoming and outgoing network traffic? ☐ Is network segmentation implemented to separate critical devices and servers from the rest of the network?
User authentication and management	☐ Are strong password policies enforced, and is multifactor authentication considered for accessing critical systems? ☐ Are staff regularly trained on cybersecurity best practices and phishing awareness? ☐ Are comprehensive logs and audit trails maintained for all system and user activities to promptly detect and respond to suspicious behavior?
Vendor and third-party management	☐ Do all vendors comply with strict cybersecurity standards as outlined in service-level agreements? ☐ Are regular security assessments conducted for third-party vendors who have access to the systems or data?
Incident response and business continuity	☐ Is there a developed and maintained incident response plan that includes procedures for responding to cybersecurity incidents? ☐ Are regular drills conducted to test the effectiveness of the incident response plan? ☐ Are robust data backup and disaster recovery procedures implemented to ensure data can be restored quickly after a cyber incident? ☐ Is there a clear process for linking downtime reports to corresponding images on temporary storage in a way amenable to postrecovery reconciliation?
Compliance and legal requirements	☐ Is the practice compliant with relevant regulations such as HIPAA or GDPR, which govern the security and privacy of medical information? ☐ Are privacy policies reviewed and updated regularly to align with current laws and best practices?
Physical security	☐ Is physical access to facilities housing critical infrastructure and sensitive data controlled? ☐ Are environmental controls in place to protect equipment from unauthorized visitors and natural threats such as earthquake, water damage, or excessive heat?
Continuous improvement	☐ Are there regularly scheduled security audits and penetration testing to identify and rectify vulnerabilities? ☐ Is there a feedback mechanism to learn from security incidents and continuously improve security measures?

GDPR = General Data Protection Regulation

Table 3. Checklist for Identifying Vulnerable Imaging Technology

Category	Checklist Items
Inventory of software and hardware devices	☐ Have all imaging modalities (eg, MRI, CT, x-ray, ultrasound) been listed, including their make, model, and firmware version? ☐ If a proxy or gateway firewall is used for an imaging modality, have all such firewalls been listed, including make, model, and firmware version? ☐ Are the operating systems and software versions used on each imaging device documented? ☐ Are workstations for downtime use—or the flashing media for creating them—properly secured, dated, and maintained? ☐ Have all imaging workstations managed by the radiology department or practice been listed (eg, technologist, radiologist, subspecialist stations such as in orthopedic surgery and cardiology)? ☐ Is there an up-to-date list of all servers associated with these devices?
Network infrastructure	☐ Is there a complete map of the network infrastructure connecting imaging devices, including routers, switches, and firewalls? ☐ For wireless-enabled modalities such as portable x-ray, are all wireless access points and their security protocols (eg, WPA2 [Wi-Fi-protected access 2], WPA3 [Wi-Fi-protected access 3]) included in the inventory? ☐ Is network segmentation part of the cybersecurity strategy (eg, are radiology devices and workstations on a separate network)? ☐ Is there documentation on the network segmentation strategy that isolates critical devices and servers?
Data storage and management systems	☐ Are all systems used for imaging data management, such as PACS, RIS, VNA, and reporting, inventoried with details on their on-premise or cloud-based location and security measures, along with their make, model, and version? ☐ Is there an inventory of all backup systems and their configurations? ☐ Are data encryption measures at rest and in transit documented for each system? ☐ Is there a process to regularly extract data from offline modalities' temporary storage during prolonged downtime to accommodate automatic purging? ☐ What storage resources, such as portable media or temporary external drives, have been procured for image storage during prolonged downtime?
Software applications	☐ Is there a list of all software applications used in the radiology workflow, including AI and image analysis tools? ☐ Are the software versions and patch statuses documented? ☐ Are any third-party or custom-developed applications identified and reviewed for compliance with security policies?
Access control systems	☐ Are all systems that require user authentication, including imaging equipment, storage systems, and software applications, listed with details on the type of authentication used? ☐ Is there an inventory of all users with access to these systems, categorized by level of access? ☐ Are the protocols for managing user access rights, such as additions, deletions, and modifications, well documented?
Vendor-specific information	☐ Is there detailed information on all vendors for hardware, software, and IT services used within the radiology department? ☐ Are contact details and support agreements available for each vendor? ☐ Is there a process for regularly reviewing and updating vendor security practices and compliance with industry standards?

(continued)

Table 3. Continued

Category	Checklist Items
Security measures and protocols	☐ Are all installed security measures included in the inventory, such as antivirus software, firewalls, and intrusion detection systems? ☐ Is there a documented protocol for updating security measures and responding to vulnerabilities? ☐ Are training records for cybersecurity awareness among radiology staff maintained and regularly updated?
Compliance and audit	☐ Is there documentation that verifies compliance with relevant regulations such as HIPAA, GDPR, or others applicable to the location and operation? ☐ Are the results from the most recent security audits and assessments available? ☐ Is there a schedule for future compliance checks and security audits?
Regular update cycle	☐ Has a refresh of the Vulnerable Imaging Technology inventory been regularly scheduled?

AI = artificial intelligence; RIS = Radiology Information System; VNA = vendor-neutral archives; GDPR = General Data Protection Regulation.

infrastructure outside the enterprise network (eg, cloud-based), or in a hybrid configuration. This reliance means unauthorized access and data breaches are growing concerns, with misconfigured PACS servers having exposed millions of patient studies [8-10]. Ransomware attacks can encrypt imaging data, disrupt clinical workflows, delay patient care, and even lead to permanent patient data loss [11,12].

Although cloud providers reduce the effort needed to manage physical security and infrastructure, they do not obviate important cybersecurity protection measures. In particular, securing applications and data remains the responsibility of the application vendor and local hospital or radiology practice. The cybersecurity vulnerabilities of cloud-based solutions may also be opaque to the radiology practice due to third-party management. Therefore, protection involves new administrative needs, new technical demands for data encryption during transmission and in remote storage, and verifying vendor compliance with health care regulations, including data residency and sovereignty requirements [13].

AI infrastructure adds a layer of complexity. At a basic level, integrating AI tools creates new points of exposure. Additionally, AI models can suffer from adversarial attacks—in which malicious inputs deceive AI models—and be misled to generate false inferences [11,12,14]. AI models might not exhibit obvious signs of cognitive compromise and could quietly insert incorrect outputs into systems of record and require efforts to enhance or develop performance drift and monitoring mechanisms [11]. There is an increasing use of third-party AI orchestration platforms, which offer several advantages, including improved efficiency, scalability, and quality. However, like the use of cloud in standard imaging operations, these also pose the risk of a single point of failure.

To meet the growing demands of patients seeking care across different health systems or geographical locations, as well as the needs of research and AI development, recent years have seen a substantial increase in demand for image sharing. The ACR strongly advocates for the elimination of physical media [15]. However, the adoption of digital image sharing comes with its own security considerations for electronic protected health information (ePHI) management.

To protect the multitude of physical, virtual, and software assets, as well as data, in daily radiology operations and for image sharing, various safeguards—including physical, technical, and administrative controls—may be implemented. Some of them apply across multiple settings, some are mandated by law, and some are best practices. The next section outlines a representative set of these safeguards, along with their operational, technical, and regulatory implications.

SAFEGUARDS IN OPERATIONAL SECURITY IN RADIOLOGY

Some portions of the 2019 Practice Parameter outline procedures for safeguarding ePHI continue to be relevant [16]. At the core of these procedures is an emphasis on the importance of administrative, physical, and technical safeguards by the HIPAA Security Rule [17], under the broader Title 45 Part 164 Subpart C of the US Code and Federal Regulations [18-20]. This section offers a high-level overview of relevant safeguards but is not intended to be a comprehensive regulatory guide. Tables 1 and 2 combine many of these concepts in the context of specific vulnerabilities into a checklist.

Physical Safeguards

These physical barriers protect data and systems from unauthorized access or damage.

Access Control. To control access to sensitive areas in radiology, multiple layers of nested security are used, such as securing the hospital, the radiology department, the imaging rooms, and the devices (eg, servers and workstations). It can involve locked doors, biometric scans, key cards, and device-specific security measures like disabling USB ports on workstations. Security systems, such as alarms and surveillance cameras, help detect and monitor activity in real time. Protocols for the secure disposal of outdated devices, media, and records ensure that no sensitive information is left exposed.

Environmental Protection. Radiology equipment is highly sensitive to environmental changes. Electronic devices require specific fire protection systems, such as gas systems, as well as temperature and humidity control, to safeguard equipment and data. Backup power sources, such as uninterruptible power supplies and generators, ensure critical systems remain operational during power outages.

Physical safeguards also include a facility-level physical security plan and contingency operations in the case of lost data [19].

Technical Safeguards

These are the security measures implemented by technology systems. A “defense in depth” strategy is the best practice, involving the use of multiple technical safeguards simultaneously.

De-Identification. Personally identifiable information (PII) may be present in reports, images, and associated image metadata. Not all health care data exchange must involve data de-identification. In some situations, such as disclosure to the patient, for operational use, billing, or as required by law, PII is permitted. In other situations, individuals may expressly authorize the disclosure of PII. If de-identification is required, the requirements for de-identification are defined by HIPAA and Health Information Technology for Economic and Clinical Health Act (HITECH) through CFR §164.514 and generally falls into two methodologies: (1) expert determination, in which a qualified person applies statistical and scientific principles to determine that the risk of reidentification is very small, or (2) safe harbor method, in which all 18 predefined elements of identifiers are removed from all shared data [21].

Access Control. Secure technical access to all maintained systems must be subject to access control policies and procedures. Passwords, multifactor authentication, proper authorization, regular accounting, and role-based access control ensure that only authorized personnel can access the right sensitive information in a trackable fashion. Role-based access control also ensures that users can only view the data necessary for their tasks. A proper combination of authentication,

authorization, and accounting is also known as the AAA model of access control. Access control safeguards also apply to remote access and cloud-based applications.

Monitoring and Auditing. To comply with HIPAA/HITECH and other applicable federal regulations (eg, 21 CFR §11.10(e) and 45 CFR §164.312(b)), health care organizations must maintain secure, computer-generated, time-stamped audit trails for all activities in systems that store or process ePHI [20,22]. These detailed, granular logs should be periodically reviewed, by 45 CFR §164.308(a)(1)(ii)(c), to detect any irregular patterns, suspicious activity, or potential breaches and retained for a period that meets or exceeds the statutory requirements for maintaining the associated medical records. Audit and monitoring for compliance with HIPAA also applies to third-party contractors and vendor-managed solutions used in clinical operations.

Data Encryption and Backup. Data confidentiality, integrity, and availability are critical in radiology and are commonly referred to as the CIA triad, as advocated by the National Institute of Standards and Technology [23]. Encryption of personally identifiable data at rest (eg, encrypted drives) and in transit (eg, TLS [Transport Layer Security] and SSL [Secure Sockets Layer] transmission protocols) is an addressable concern under the HIPAA Security Rule [17]. Some state laws supplement HIPAA with more stringent requirements; for instance, Massachusetts 201 CMR 17.00 mandates “encryption of all transmitted records and files containing personal information” and “encryption of all personal information stored on laptops or other portable devices” [24]. Integrity controls, including the use of hashes and digital signatures, along with secure data-sharing protocols, ensure that data remain unaltered. Cloud-based, off-site, or air-gapped backups also contribute to rapid recovery from data loss or ransomware attacks.

Network Security. Broadly, network security consists of perimeter security and segmentation. Although not mandated, a “reasonable and appropriate technical safeguard” by the HIPAA Security Rule implies the need for a strong perimeter security to protect the transmission of medical images when transferring over a network. Examples include software and hardware firewalls that regulate incoming as well as outgoing traffic and intrusion detection and prevention systems that inspect and can act on network data [17,25]. Virtual Private Networks are software or hardware solutions that use data encryption to allow an external device to appear and be used as though it is inside the firewall of a private network [17]. Network segmentation involves physically or logically separating different parts of a health care system’s IT infrastructure to limit the damage from security compromises and can be achieved using either hardware- or software-

defined approaches. Network segmentation is commonly cited as a principal method that keeps an unfortunate network breach from becoming a catastrophic one [12,26,27]. Under the current HIPAA Security Rule, both perimeter security and segmentation are “addressable” implementation specifications: Covered entities must assess whether they are “reasonable and appropriate” to their environment and, if so, deploy them or document why an alternative safeguard suffices [17].

End Point Protection. The term “end points” refers to devices that can serve as entry points into a network. Although not strictly mandated by law, the voluntary guidelines from Health Industry Cybersecurity Practices and recent recommendations from the FDA establish the use of antimalware software and device management policies on connected devices as best practice [28,29]. Connected end points in medical imaging range from imaging modalities to PACS servers, workstations, and mobile telephones that can access data. Additional best practices include device hardening technical policies, such as adopting the latest vendor security configurations, disabling unused ports, and white listing allowed applications. Regular updates and security patches help mitigate vulnerabilities.

Administrative Safeguards

These are the rules, policies, and procedures to manage security practices per CFR 45 §164.308 [18].

Risk Assessment. CFR 45 §164.308 mandates regular risk assessments and periodic evaluations to identify vulnerabilities in systems, networks, and data storage methods [18]. These assessments help develop strategies to mitigate risks and prepare for potential security breaches. To address breach notification mandates, best practices for risk assessment should also include establishing protocols for breach notification and penetration testing [17,30,31].

Policies and Procedures. Administrative leadership is responsible and accountable for building clear policies regarding access control, data encryption, and device management for systems they maintain [18,20]. Policies for access control should handle privilege requests and approvals for local staff and third parties, regular audits of access rights, and role change management. Well-defined procedures for monitoring systems, managing incidents, and controlling changes help protect patient data. Specific protocols governing the access, retention, and disposal of radiology records help maintain compliance and must be integrated with the broader hospital policies.

Workforce Management. Cybersecurity awareness and training for all workforce members is mandatory by the HIPAA Security Rule at a reasonable and appropriate interval [17]. The HITECH Act adds civil-monetary penalty

maximums for all HIPAA violations, introduces breach notification requirements, and adds additional penalties for failures to provide (and document) effective cybersecurity training [30]. A training program must cover security incident recognition and reporting, password management, workstation security, and protection against social engineering attacks. Most successful ransomware attacks have relied on social engineering, such as phishing, to access systems, and clinical practices should assume a breach attempt is already in progress, if not already successful. Proper termination procedures must be followed when employees leave or change roles.

Vendor Management. Administrative policies and procedures of a facility should also apply to third-party contractors and vendor-managed solutions, such as proactively enabling security features as default configurations. This also includes a cybersecurity bill of materials for any “cyber devices,” including software as a medical device purchases under the Food, Drug & Cosmetics Act section 524B [32]. An agreement, usually a business associate agreement, can give radiology practices the right to be notified about security breaches that affect a vendor platform or the data contained therein. A master service agreement or the business associate agreement can also offer provisions for audit rights to vendor software access logs for compliance and security monitoring.

Incident Response and Recovery. An effective incident response plan defines roles and responsibilities during a security breach and includes reporting mechanisms, escalation, procedures for recovery, and postincident analysis. Regular drills ensure the team is prepared for potential incidents, and disaster recovery plans improve the odds of business continuity in the event of a breach or system failure [33].

Compliance and Governance. Radiology practices must comply with federal as well as relevant state laws and regulations to ensure their security practices meet legal standards. Regular security audits and a dedicated security officer ensure all policies are followed and updated.

MANAGING RISK DURING AND AFTER A DISABLING RANSOMWARE ATTACK

A major challenge in planning for extended, catastrophic downtime is the misplaced confidence employees and departments may have after managing shorter or less extensive downtimes, such as during software or network upgrades.

Reacting to a ransomware attack is different.

Although many nontechnical staff might consider the unavailability of the electronic medical records system as the primary concern during a ransomware attack, the actual

impact is much broader. For example, Internet Protocol telephony, file sharing and document access, intranet web portals, and PACS and vendor-neutral archives infrastructure are examples of technologies not available during a ransomware event. Since some ransomware events can last 4 to 6 weeks or more, staff must also prepare for risks that accumulate over prolonged downtimes, such as payroll management, ordering supplies, modalities running out of local storage for examinations, and tracking of manually created diagnostic reports [34].

Management strategies to mitigate these risks include educating the technical and nontechnical staff team on the unique aspects of a prolonged total network outage, allocating resources to mitigate and recover from such attacks, creating redundancy and forms of technical separation to mitigate the extent of the attack, and preparing a disaster recovery plan. Conducting tabletop exercises with senior leaders to simulate the types of decisions that will need to be made as time elapses can provide valuable education on why traditional downtime strategies are unlikely to be effective in the event of a catastrophic ransomware incident [35]. Simulation and downtime drills are explored in more depth in the section “Continuous Improvement Through a Culture of Security.”

Health systems addressing a cyber event will likely require three different teams to coordinate their activities:

- A cyber response team that liaises with law enforcement and insurance firms. The team is also responsible for making decisions regarding internal and external notifications. Once the extent of damage is known, breach notification to Health and Human Services or affected individuals may be relevant [30,31]. The US Federal Bureau of Investigation strongly discourages direct negotiation with, or payment to, ransomware actors [36].
- An incident command team that employs standard incident command methodology to communicate and evaluate the response to an emergency. Table 4 outlines the members of the incident command team and their respective roles.
- Technology response teams are responsible for the technical tasks of assessing the extent of the attack, evaluating the viability of backups, and developing restoration plans for different scenarios, such as bare metal restore versus file restoration.

Additional team structures and expanded descriptions of responsibilities may be found in the National Institute of Standards and Technology Special Publication 800-61 [37].

Communication plans must consider the possibility that standard communication channels might be inoperable in an emergency, in part mandated by the CMS Condition of Participation (§482.15) [38]. For leadership communications, a system outside the usual e-mail and Internet Protocol

Table 4. Roles and responsibilities of the incident command team responding to a cyber attack

Role	Responsibilities
Incident commander	Oversees the entire response effort, makes strategic decisions, coordinates communication between teams and external stakeholders
Technical lead	Directs the technical response, identifies and contains the threat, assesses damage, restores systems, collaborates with IT staff and external consultants
Communications officer	Manages internal and external communications, ensures stakeholders are informed, uses alternative communication channels if needed
Legal advisor	Provides guidance on legal matters, regulatory compliance, reporting obligations, interactions with law enforcement
Public relations specialist	Handles media inquiries, makes public statements, manages the organization's reputation, maintains public trust
Business continuity planner	Develops and implements plans to ensure critical business functions continue during and after the incident
Human resources representative	Addresses staffing needs and employee communication, provides support to affected staff members

telephony channels is best practice, potentially using cellular capabilities. Within hospitals, two-way radios may be the most reliable form of distributed communication during a networkwide outage. Public and social media can serve as a method of communicating with employees and patients. Although liability concerns sometimes discourage extensive communication, maintaining stakeholders' trust requires open and frequent communication.

To prepare for a systemwide outage, as often observed in ransomware incidents, clinical systems should be categorized to determine both the priority for restoration and the need for comprehensive and tested downtime procedures [34]. As systems are gradually restored, workflows may become unpredictable due to partial network and system recovery, which could last for several days or even weeks. Additionally, when resuming operations using manual or improvised interpretation processes, be aware of human errors. Executing plans for postrecovery reconciliation of reports and their

associated images, management of provider communication of critical findings, and tracking follow-up of incidental findings can be complex and laborious. A process codeveloped with risk management may be necessary to address critical findings discovered after incident recovery—potentially months later—to assess and mitigate patient impact from delayed diagnosis. It is also important to understand the effect of manual workflow on billing, as delays can limit collections for professional and facility charges, and missed collections may cause surprise billing to patients once the episode of care is complete. Once all systems are recovered, a debrief of the event should be made to understand the cause of failure and any management strategies needed to mitigate future occurrences, including resource allocation.

CONTINUOUS IMPROVEMENT THROUGH A CULTURE OF SECURITY

Effective prevention and recovery in the setting of a cyber-attack relies not only on robust downtime processes, but also on the team of people who implement those procedures [39]. Developing policies and procedures for responding to cyber or ransomware attacks requires a substantial investment of both time and resources. These efforts should be viewed as an investment against an inevitable

disruption, rather than as contingency plans against an unlikely event.

The first step in building a response plan to a ransomware-type attack is to form a committee to head the effort [39]. Relevant stakeholders from across the radiology practice and hospital, including IT staff, physicians, technologists, and administrative personnel, should all be represented [34]. The Technical Resources, Assistance Center, and Information Exchange, created by the Administration for Strategic Preparedness and Response of Health and Human Services, offers a Cyber Response Checklist and Cyber Incident System Restoration Checklist, which can serve as a starting point for radiology departments or private practices looking to develop unit-specific response plans [40,41]. However, empowering the group to create customized downtime procedures that take into account unique aspects of the organization will result in more relevant and resilient plans [33].

With processes and procedures, the next step in establishing an ongoing culture of safety is to routinely perform simulations and drills for both expected and unexpected downtime challenges, such as through mock outages, tabletop exercises, or computer simulations [35,42]. The training frequency varies depending on the organization's specific needs and size and on the nature of the training.

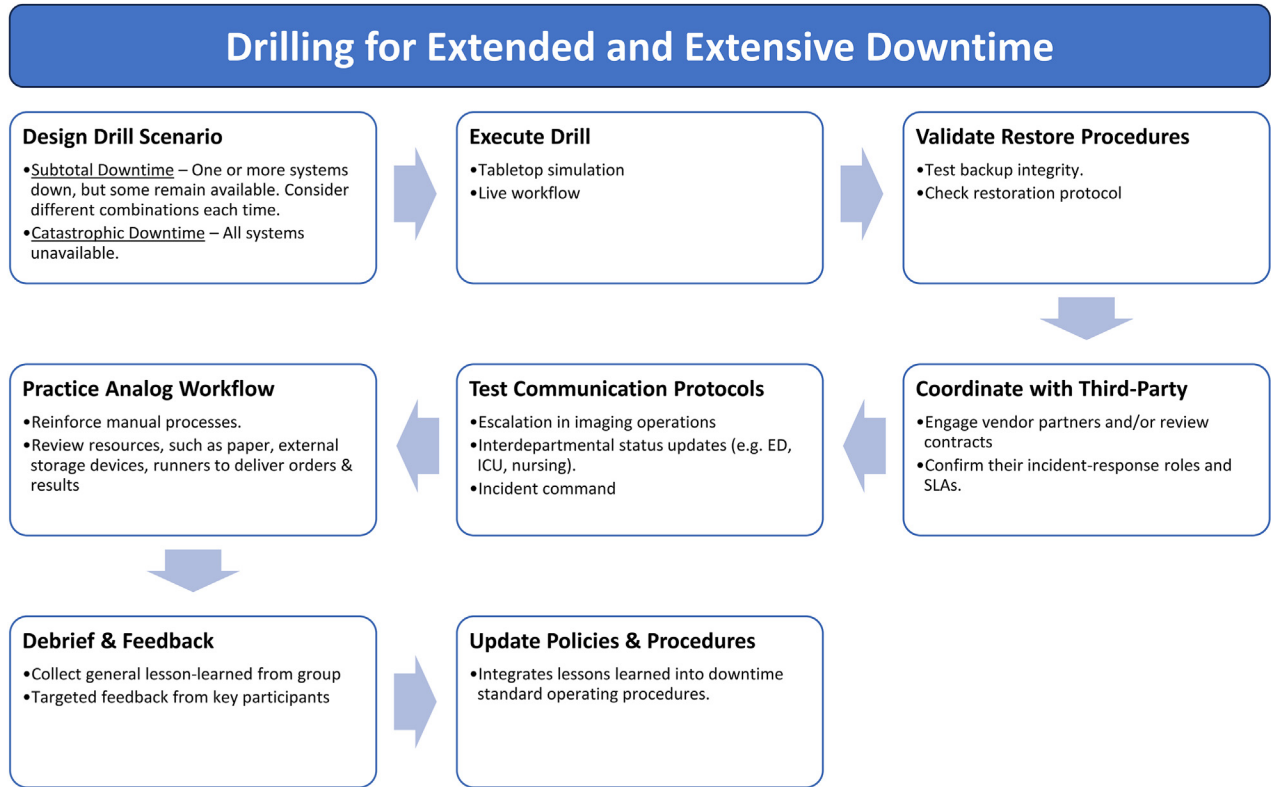


Fig. 1. Drilling for extended and extensive downtime. ED = emergency department; ICU = intensive care unit; SLA = service-level agreements.

Downtime drill content should vary from session to session. Simulations might include a response to specific system(s) being down or all systems being down simultaneously. By drilling for both types of threats, deep dives into protocols and procedures for the outage of a specific system can be balanced with strategies to approach a more extreme event involving all systems. A debriefing opportunity is strongly recommended, both by the larger group to gather feedback and by the smaller downtime leadership committee to act on that feedback to effect meaningful changes in protocols. [Figure 1](#) outlines one possible workflow for downtime drills.

Establishing a culture of safety is a challenging yet important part of building resilience. With a dedicated group of downtime champions, the larger department can more effectively simulate and practice different downtime contingencies, refining procedures and protocols through frequent exercises.

CONCLUSION

The ACR and the SIIM are committed to safeguarding medical imaging. The daily operations of radiology and enterprise imaging departments increasingly rely on technology that has become ever more interconnected within and across a health network. Protecting hospital operations means methodically fortifying the medical imaging pipeline, training the caregivers on the frontline, and developing incident response and recovery strategies. Ultimately, a security culture necessitates consistent training, simulations, and active leadership involvement. Taken together, these multidisciplinary interventions can minimize the data risk, privacy concerns, and financial implications of data breaches and disabling attacks and help maintain patient trust.

TAKE-HOME POINTS

- Modern radiology is highly vulnerable to cyberattacks; protecting data, devices, and workflows requires layered administrative, physical, and technical safeguards throughout all operations.
- Effective incident response, including multiteam coordination and regular simulation drills, can improve the odds of clinical continuity during ransomware or technology outages.
- Robust staff training and administrative oversight are critical; most successful cybersecurity threats exploit human behavior, making ongoing education central to security.
- Cloud and AI integration increase complexity and potential vulnerabilities, but risks can be mitigated

through data encryption, vendor compliance, and monitoring for adversarial threats.

- Building a proactive culture of cybersecurity with regular downtime drills benefits patient safety, minimizes downtime, and sustains patient trust in a rapidly evolving, interconnected medical imaging landscape.

DECLARATION OF GENERATIVE AI AND AI-ASSISTED TECHNOLOGIES IN THE WRITING PROCESS

During the preparation of this work the authors used Microsoft Copilot and Grammarly in order to copyedit the manuscript. After using this tool/service, the authors reviewed and edited the content as needed and take full responsibility for the content of the publication.

REFERENCES

1. Breach Portal: Notice to the Secretary of HHS Breach of Unsecured Protected Health Information. Office for Civil Rights portal of health information breaches affecting 500 or more individuals. Available at: https://ocrportal.hhs.gov/ocr/breach/breach_report.jsf. Published 2025. Accessed February 22, 2025.
2. Alder S. Change healthcare responding to cyberattack. The HIPAA Journal. Available at: <https://www.hipaajournal.com/change-healthcare-responding-to-cyberattack/>. Published 2024. Accessed February 22, 2025.
3. Warner MR. Cybersecurity is patient safety. Office of Senator Mark R. Warner. Available at: https://www.warner.senate.gov/public/_cache/files/f/5/f5020e27-d20f-49d1-b8f0-bac298f5da0b/0320658680B8F1D29C9A94895044DA31.cips-report.pdf. Published 2022. Accessed February 22, 2025.
4. Whitfill J. Data security and patient privacy. In: Branstetter BFI, ed. *Practical imaging informatics: foundations and applications for medical imaging*. 2nd ed. New York, NY: Springer; 2021:119-30.
5. European Society of Radiology (ESR). Renewal of radiological equipment. *Insights Imaging* 2014;5:543-6.
6. Das Gupta S, Shah D. Safeguarding the future of radiology with imaging informatics. AuntMinnie.com. Available at: <https://www.auntminnie.com/imaging-informatics/cybersecurity/article/15667408/safeguarding-the-future-of-radiology-with-imaging-informatics>. Published March 28, 2024. Accessed April 4, 2025.
7. Grimes SL, Wirth A. The case for medical device cybersecurity hygiene practices for frontline personnel. *Biomed Instrum Technol* 2021;55:96-9.
8. Alder S. Radiology specialists facing class-action lawsuit over PACS data breach. HIPAA Journal Available at: <https://www.hipaajournal.com/radiology-specialists-facing-class-action-lawsuit-over-pacs-data-breach/>. Published 2021. Accessed April 4, 2025.
9. Davis J. Millions of medical images, patient data remain exposed via PACS flaws. SC Media. Available at: <https://www.scworld.com/news/millions-of-medical-images-patient-data-remain-exposed-via-pacs-flaws>. Published 2021. Accessed April 4, 2025.
10. Cawthra J, Kuruvilla J, Littlefield K, et al. Securing picture archiving and communication system (PACS): cybersecurity for the healthcare sector. National Institute of Standards and Technology (NIST). Available at: <https://www.nccoe.nist.gov/publication/1800-24/VolA/>. Published December 2020. Accessed April 4, 2025.
11. Shah C, Nachand D, Wald C, Chen PH. Keeping patient data secure in the age of radiology artificial intelligence: cybersecurity considerations and future directions. *J Am Coll Radiol* 2023;20:828-35.

12. Kelly BS, Quinn C, Belton N, Lawlor A, Killeen RP, Burrell J. Cybersecurity considerations for radiology departments involved with artificial intelligence. *Eur Radiol* 2023;33:8833-41.
13. Zandesh Z. Privacy, security, and legal issues in the health cloud: structured review for taxonomy development. *JMIR Form Res* 2024;8:e38372.
14. Mirsky Y, Mahler T, Shelef I, Elovici Y. CT-GAN: malicious tampering of 3D medical imagery using deep learning. *arXiv*. Published 2019. Available at: <http://arxiv.org/abs/1901.03597>. Accessed February 8, 2023.
15. McGinty G. #DitchtheDisk. *J Digit Imaging* 2022;35:737-8.
16. American College of Radiology. ACR–AAPM–SIIM practice parameter for electronic medical information privacy and security. Available at: <https://gravitas.acr.org/PPTS/DownloadPreviewDocument?DocId=104> Accessed 7/24/2025. Published January 2019.
17. US Department of Health and Human Services. The HIPAA Security Rule Available at: <https://www.hhs.gov/hipaa/for-professionals/security/index.html>. Accessed August 23, 2025.
18. Code of Federal Regulations. Title 45, §164.308: administrative safeguards. National Archives. Available at: <https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308>. Accessed November 4, 2025.
19. Code of Federal Regulations. Title 45, §164.310: physical safeguards. National Archives. Available at: <https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.310>. Accessed November 4, 2025.
20. Code of Federal Regulations, Title 45, §164.312: technical safeguards. National Archives. Available at: <https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.312>. Accessed November 4, 2025.
21. US Department of Health and Human Services. The HIPAA Privacy Rule Available at: <https://www.hhs.gov/hipaa/for-professionals/privacy/index.html>. Accessed August , 2025.
22. Code of Federal Regulations. Title 21, §11.10: controls for closed systems. National Archives. Available at: <https://www.ecfr.gov/current/title-21/chapter-I/subchapter-A/part-11/subpart-B/section-11.10>. Accessed November 4, 2025.
23. National Institute of Standards and Technology. NIST Special Publication 1800-26 Available at: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.1800-26.pdf>. Accessed April 11, 2025.
24. Office of Consumer Affairs and Business Regulation. 201 CMR 17.00: standards for the protection of personal information of residents of the commonwealth. Available at: <https://www.mass.gov/doc/201-cmr-17-standards-for-the-protection-of-personal-information-of-residents-of-the-commonwealth/download>. Published November 2009. Accessed April 16, 2025.
25. Hady AA, Ghubaish A, Salman T, Unal D, Jain R. Intrusion detection system for healthcare systems using medical and network data: a comparison study. *IEEE Access* 2020;8:106576-84.
26. Nguyen XV, Petscavage-Thomas JM, Straus CM, Ikuta I. Cybersecurity in radiology: cautionary tales, proactive prevention, and what to do when you get hacked. *Curr Probl Diagn Radiol* 2024;54(2): 245-50.
27. Eichelberg M, Kleber K, Kämmerer M. Cybersecurity in PACS and medical imaging: an overview. *J Digit Imaging* 2020;33:1527-42.
28. US Food and Drug Administration. Cybersecurity in medical devices: quality system considerations and content of premarket submissions, guidance for industry and food and drug administration staff. Available at: <https://www.fda.gov/media/119933/download>. Published 2023. Accessed April 16, 2025.
29. US Department of Health and Human Services. Health industry cybersecurity practices: managing threats and protecting patients (HICP) Available at: <https://405d.hhs.gov/Documents/HICP-Main-508.pdf>. Published 2023. Accessed April 16, 2025.
30. Health Information Technology for Economic and Clinical Health (HITECH) Act. Available at: <https://www.govinfo.gov/content/pkg/PLAW-111publ5/pdf/PLAW-111publ5.pdf>. Published 2009. Accessed April 16, 2025.
31. US Department of Health and Human Services. Breach Notification Rule. Available at: <https://www.hhs.gov/hipaa/for-professionals/breach-notification/index.html>. Published 2013.
32. Federal Food, Drug, and Cosmetic Act, §524B. Available at: <https://www.federalregister.gov/documents/2025/06/27/2025-11669/cybersecurity-in-medical-devices-quality-system-considerations-and-content-of-premarket-submissions>. Accessed April 16, 2025.
33. Larsen E, Hoffman D, Rivera C, Kleiner BM, Wernz C, Ratwani RM. Continuing patient care during electronic health record downtime. *Appl Clin Inform* 2019;10:495-504.
34. Chen PH, Bodak R, Gandhi NS. Ransomware recovery and imaging operations: lessons learned and planning considerations. *J Digit Imaging* 2021;34:731-40.
35. Maggio LA, Dameff C, Kanter SL, Woods B, Tully J. Cybersecurity challenges and the academic health center: an interactive tabletop simulation for executives. *Acad Med* 2020;96(6):850-3. Nov 24.
36. Federal Bureau of Investigation. Ransomware prevention and response for CISOs. Available at: <https://www.fbi.gov/file-repository/ransomware-prevention-and-response-for-cisos.pdf/view/>. Published 2016. Accessed July 24, 2025.
37. Nelson A, Rekhi S, Souppaya M, Scarfone K. Incident response recommendations and considerations for cybersecurity risk management : a CSF 2.0 community profile [Internet]. Gaithersburg, MD: National Institute of Standards and Technology [cited 2025 Jul 24]. Available from: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r3.pdf>. 2025 Apr.
38. Centers for Medicare & Medicaid Services. US Department of Health and Human Services. 42 CFR §482.15: condition of participation: emergency preparedness. Available at: <https://www.govinfo.gov/content/pkg/CFR-2018-title42-vol5/pdf/CFR-2018-title42-vol5-sec482-15.pdf>. Published 2025. Accessed July 24, 2025.
39. Jalali MS, Kaiser JP. Cybersecurity in hospitals: a systematic, organizational perspective. *J Med Internet Res* 2018;20:e10059.
40. ASPR TRACIE. Cyber incident response checklist. Available at: <https://files.asprtracie.hhs.gov/documents/healthcare-system-cybersecurity-incident-response-checklist.pdf>. Published 2021. Accessed April 24, 2025.
41. ASPR TRACIE. Cyber incident system restoration checklist. Available at: <https://files.asprtracie.hhs.gov/documents/healthcare-system-cybersecurity-incident-system-restoration-checklist.pdf>. Published 2020. Accessed April 24, 2025.
42. Ghayoomi H, Laskey K, Miller-Hooks E, Hooks C, Tariverdi M. Assessing resilience of hospitals to cyberattack. *Digit Health* 2021;7: 20552076211059366.